

Supply Chain Attacks: Impact, Examples, and 6 Preventive Measures

What Are Software Supply Chain Attacks?

A software supply chain attack refers to a cyberattack that focuses on an organization's software or service providers within its digital supply chain. The main objective of these attacks is to breach the target organization by exploiting vulnerabilities in the systems of its vendors or suppliers. This enables attackers to gain unauthorized access to sensitive data and resources, disrupt operations, or harm the organization's reputation.

This is part of a series of articles about [cybersecurity attacks](#).

Effects of Supply Chain Attacks

Supply chain attacks can lead to severe consequences for organizations, their clients, and even entire industries. These include:

Financial Losses

Organizations that fall victim to supply chain attacks often experience considerable financial losses due to system downtime, lost revenue, and costs associated with remediation. Furthermore, these companies may suffer reputational damage, which could result in the loss of business partners or customers.

[Data Breaches](#)

Successful supply chain attacks can cause extensive data breaches involving sensitive information such as customer records, intellectual property (IP), trade secrets, or classified government documents. These breaches not only impact the targeted organization but also affect its clients who entrusted them with their valuable data.

Trust Erosion

When an organization is compromised by a supply chain attack, trust among its stakeholders—such as customers, suppliers, and investors—erodes. Rebuilding this trust can be challenging and may lead to long-term damage that goes beyond immediate financial losses.

National Security Risks

Supply-chain attacks that compromise critical infrastructure—like power grids, water supplies, or transportation systems—pose a threat to national security. These attacks can disrupt essential services and impact entire populations.

Regulatory Penalties

Organizations impacted by supply chain attacks may face regulatory penalties if they fail to comply with data protection laws such as the GDPR or CCPA. Non-compliance can result in substantial fines and legal consequences.

How Do Supply Chain Attacks Happen?

Following are some of the most common causes of supply chain attacks:

Exploiting Software Dependencies

Modern applications often depend on open-source libraries and frameworks maintained by third parties. These components can pose security risks if they contain unpatched vulnerabilities or are tampered with during development or distribution. In these scenarios, attackers can exploit these weaknesses to compromise the entire application stack.

Hijacking Vendor Systems

Attackers may also target vendors directly by breaching their networks and gaining access to critical systems such as customer databases or source code repositories. Once inside the network perimeter of a trusted partner organization, attackers can manipulate data transmissions between companies or inject malicious payloads into legitimate software updates that spread throughout the entire ecosystem.

Insider Threats

In some instances, supply chain attacks can be enabled by malicious insiders with privileged access to sensitive information or systems. These individuals may intentionally leak data, sabotage critical infrastructure, or collaborate with external threat actors to execute targeted cyberattacks against their own organizations.

Social Engineering Attacks

Attackers may employ social engineering tactics like phishing emails or impersonation scams to manipulate employees into disclosing sensitive information or granting unauthorized system access. By targeting unsuspecting staff members within the supply chain network—especially those in key decision-making roles—criminals can exploit human weaknesses to bypass even the most advanced technical defenses

Examples of Supply Chain Attacks

One of the most notorious supply chain attacks in history is the SolarWinds Orion attack. In 2023, cybercriminals infiltrated SolarWinds' software development environment and embedded malicious code within the Orion platform updates. Consequently, around 18,000 organizations inadvertently installed backdoors on their systems through regular software updates. The perpetrators accessed confidential data from numerous government agencies and private companies worldwide.

NotPetya Ransomware Attack

The NotPetya ransomware attack in 2017 targeted Ukrainian accounting software provider MeDoc via a harmful update mechanism. NotPetya rapidly propagated across international networks using the EternalBlue exploit (an NSA hacking instrument leaked by the Shadow Brokers), encrypting files and rendering systems inoperable for many global businesses. The NotPetya attack resulted in financial damage estimated at over \$10 billion.

CCleaner Malware Incident

In 2017, the widely-used system optimization tool CCleaner fell prey to a supply chain attack when hackers introduced malware into the software's installer. The attack granted hackers access to data from over 2 million users, potentially enabling unauthorized control of the affected systems.

ASUS Live Update Attack

In 2023, a supply chain attack called "Operation ShadowHammer" targeted the Live Update utility used by millions of ASUS devices. Cybercriminals embedded malicious code into genuine updates for the tool, compromising thousands of computers globally. This sophisticated attack remained undetected for months until security researchers uncovered it

6 Ways to Mitigate Supply Chain Attacks

1. Vendor Risk Management

A vital aspect of mitigating supply chain attacks is implementing a robust vendor risk management process. This involves assessing the security posture of third-party vendors, monitoring their adherence to industry standards, and ensuring they follow secure development practices. Conduct regular audits and evaluations to confirm that vendors maintain proper security measures.

2. Patch Management

Keeping software up-to-date is essential for preventing vulnerabilities from being exploited by malicious actors. A thorough patch management policy guarantees that all systems receive regular updates with the latest patches from software vendors. Additionally, organizations should prioritize patching based on criticality and the potential impact on business operations.

3. Asset Inventory Creation

To efficiently manage patches across your environment, maintain an accurate asset inventory, including hardware devices, operating systems, applications, and network components. This helps identify vulnerable systems that need updates or replacements due to end-of-life status.

4. Sandbox Testing Before Deployment

Prioritize testing new updates in isolated environments before deploying them in production networks. This enables you to detect any compatibility issues or unexpected problems without affecting live systems.

5. User Awareness Training & Access Control Policies

- **User awareness training:** Educate employees about the risks associated with supply chain attacks and how to recognize potential threats. This includes training on phishing

awareness, social engineering tactics, and safe browsing habits.

- **Access control policies:** Implement strict access control policies based on the principle of least privilege. Limiting user permissions reduces the risk of unauthorized access or misuse of sensitive data. Additionally, use multi-factor authentication (MFA) for all privileged accounts to provide an extra layer of security.

6. Integrating Security into DevSecOps Practices

To minimize vulnerabilities in your software development lifecycle, incorporate security practices into your DevSecOps processes. This involves conducting regular code reviews, vulnerability assessments, and penetration testing throughout the development stages. By addressing security issues early in the process, you can reduce overall risk exposure while maintaining a high level of application quality.

Contacted by a hacker?	Company	Knowledge	Resources
	Leadership	Center	Blog
	Careers	Application Security	Documentation
	Partners	Penetration Testing	Leaderboard
	Newsroom	Cloud Security	Partner Portal
	Contact Us	Hacking	Resources
		Cybersecurity	
		Attacks	
		DevSecOps	